



Audit sécurité – Coach'In

1. Présentation et enjeux de sécurité du projet

Coach'In est une plateforme numérique manipulant des données sensibles : identité des utilisateurs, données sportives, échanges privés, informations professionnelles et potentiellement des flux financiers.

La sécurité informatique constitue donc un **enjeu stratégique majeur**, à la fois pour :

- la **confiance des utilisateurs**
- l'**image de marque** de la plateforme
- la **conformité réglementaire** (RGPD)

Une faille de sécurité pourrait entraîner :

- fuite de données personnelles
- atteinte à la réputation
- perte de crédibilité auprès des coachs certifiés
- sanctions légales et financières

2. Périmètre technique analysé

Technologies actuellement envisagées :

- **Frontend web** : Next.js
- **Frontend mobile** : Flutter
- **Backend API** : NestJS
- **Base de données** : PostgreSQL

Ce socle repose sur des technologies modernes, largement utilisées et s.

3. Menaces et risques principaux identifiés

3.1 Risques liés aux données personnelles

- Accès non autorisé aux profils utilisateurs
- Fuite de données sportives (poids, performances, objectifs)
- Exposition de conversations privées (chat coach / client)
- Mauvaise gestion des droits d'accès entre coachs et sportifs

Ces données peuvent être qualifiées de **données sensibles** au sens du RGPD.

3.2 Risques liés à l'authentification et aux comptes

- Vol de compte par mots de passe faibles
- Attaques par force brute ou credential stuffing
- Mauvaise gestion des sessions
- Escalade de privilèges (coach ↔ client)

3.3 Risques applicatifs courants (OWASP)

Les principales menaces identifiées sont :

- Injection SQL
- Cross-Site Scripting (XSS)
- Cross-Site Request Forgery (CSRF)
- Mauvaise gestion des permissions
- Exposition d'API non protégées

Ces vulnérabilités font partie du **Top 10 OWASP**, régulièrement exploitées.

4. Benchmark technologique sécurité

4.1 NestJS (Backend)

NestJS repose sur :

- Node.js
- Architecture modulaire
- Décorateurs et guards de sécurité

Avantages sécurité :

- Intégration native de mécanismes d'authentification (JWT, OAuth)
- Guards et interceptors pour le contrôle d'accès
- Validation stricte des entrées
- Compatibilité avec des outils de sécurité éprouvés

NestJS est utilisé par de nombreuses plateformes professionnelles, ce qui garantit un **retour d'expérience solide**.

4.2 Next.js (Web)

Avantages sécurité :

- Protection contre certaines attaques XSS par défaut
- Rendu côté serveur contrôlé
- Bon support des headers de sécurité (CSP, HSTS)
- Mise à jour régulière par l'écosystème React

4.3 Flutter (Mobile)

Avantages sécurité :

- Code compilé (difficilement modifiable)
- Pas d'exécution de code dynamique côté client
- Bon contrôle des flux réseau
- Stockage sécurisé possible via les keystores natifs

4.4 PostgreSQL (Base de données)

Avantages sécurité :

- Gestion fine des rôles et permissions
- Chiffrement des connexions (SSL/TLS)
- Outils de sauvegarde et de restauration robustes
- Moteur mature, largement audité

5. Mesures de sécurité envisagées

5.1 Authentification et autorisation

- Authentification par token sécurisé (JWT ou équivalent) ainsi que par OAuth
- Séparation claire des rôles (coach / client / admin)
- Accès aux données strictement limité au périmètre utilisateur
- Expiration et renouvellement des sessions

5.2 Protection des données

- Chiffrement des mots de passe (hashage fort)
- Connexions sécurisées (HTTPS uniquement)
- Accès restreint à la base de données
- Journalisation des actions sensibles (audit logs)

5.3 Sécurité applicative

- Validation systématique des entrées utilisateurs
- Protection contre les injections SQL
- Limitation du nombre de requêtes (rate limiting)
- Gestion des erreurs sans exposition d'informations sensibles

5.4 Sécurité organisationnelle

- Principe du moindre privilège pour les développeurs
- Séparation des environnements (dev / test / production)
- Sauvegardes régulières de la base de données
- Plan de réponse en cas d'incident de sécurité

6. Faits récents et sensibilisation aux risques

Ces dernières années, de nombreuses plateformes ont subi des incidents majeurs dus à :

- des erreurs de configuration
- des mots de passe faibles
- des API exposées publiquement

Ces événements rappellent que la sécurité ne dépend pas uniquement de la technologie, mais aussi de la **rigueur de conception** et de la **bonne compréhension des enjeux**.

Coach'In intègre cette dimension dès la phase de conception.

7. Cohérence avec le RGPD

Les mesures de sécurité envisagées sont alignées avec les obligations RGPD :

- Protection des données dès la conception (privacy by design)
- Accès limité aux données personnelles
- Traçabilité des actions
- Capacité de suppression et d'export des données

8. Limites et perspectives d'évolution

Cet audit constitue un **premier cadre de réflexion sécurité**.

À terme, il pourra être complété par :

- des audits de sécurité plus approfondis
- des tests d'intrusion
- une revue de code dédiée
- une politique de gestion des incidents

9. Conclusion

La sécurité informatique est considérée comme un **pilier fondamental du projet Coach'In**.

Le choix de technologies modernes, éprouvées et largement utilisées, associé à une approche rigoureuse des risques, permet de :

- protéger les utilisateurs
- préserver la crédibilité de la plateforme
- anticiper les exigences réglementaires et professionnelles

Cet audit démontre la **compréhension des enjeux de sécurité dès la phase de conception**, conformément aux attentes d'un projet EIP.